Data Classification and Encryption Policy

Company	Raízes Soluções e Tecnologia Ltda (CNPJ 51.467.037/0001-65)
Version	1.0
Effective date	03 November 2026
Next review	03 November 2027
Owner	Security and Privacy Officer, contato@raizesolucoes.com.br
Approved by	Management of Raízes Soluções e Tecnologia Ltda

1. Purpose

This policy defines how Raízes classifies data and which protections apply to each class.

2. Classification

- Public: information published on our website.
- Internal: internal documents and procedures.
- Confidential: customer business data (sales, inventory, invoices, financial and marketplace data).
- Restricted: credentials, tokens, secrets and personal data (including any personal data received from third-party platforms).

3. Handling rules

- Confidential and Restricted data are accessible only to authorized roles, never copied to personal devices or removable media, and never sent through unprotected channels.
- Restricted credentials are stored server-side only, in tables readable by the server role, and are never logged.
- Personal data from third-party platforms is not persisted: a field allowlist keeps only identifiers, dates, statuses, amounts and fees; names, phone numbers, emails, addresses, tax IDs and buyer IDs are discarded before storage.

4. Encryption

- In transit: TLS 1.2 or higher is mandatory for all connections between users, our services and our providers. Legacy protocols (SSL, TLS 1.0 and 1.1) are not accepted by the database server.
- At rest: personal data and all other customer data held in our databases and file storage are encrypted at rest with AES-256, as published by our cloud provider (Supabase) in its security documentation.
- Keys for provider-managed encryption are managed by the provider; application secrets are kept in secret stores or server environment variables.
- We do not use RSA for stored data. Where asymmetric keys are used (for example TLS certificates and signing), key sizes of at least 2048 bits are required.

5. Retention and disposal

Data is kept only as long as needed for the service and the law. After a contract ends, inactive data is kept for 90 days and then deleted, except records we must keep by law. Authorization tokens are deleted when the owner disconnects an integration.

6. Review

At least once a year. Owner: Security and Privacy Officer (contato@raizesolucoes.com.br).